

Security Assessment



Item 27 Internal Report

October 2026

Prepared for ether.fi





Disclaimer

This document is intended for **internal** use only.

Initial Commit Hash	Final Commit Hash
fb86a82d	91ac3252

Protocol Scope

- src/data-provider/EtherFiDataProvider.sol
- src/modules/cash/CashModuleSetters.sol
- src/modules/etherfi/LiquidUSDLiquifierOP.sol
- src/modules/frax/FraxModule.sol
- src/modules/lend-gateway/LendGateway.sol
- src/modules/lend-gateway/LendReserveLib.sol
- src/modules/midas/MidasModule.sol
- src/trading-safe/TradingSafeLiquidDepositModule.sol

Low Severity Issues

L-01 Midas vault overwrite protection can be bypassed through removal and re-registration

Severity: **Low**	Impact: **Low**	Likelihood: **Low**
Files: MidasModule.sol	Status: Fixed	

Description: The overwrite guard checks whether a redemption vault is currently configured. ADMINROLE can remove a vault and delete that configuration, after which ADMINTIMELOCK_ROLE can register a replacement without the RoleRegistry owner's approval. Because the withdrawal digest does not bind the vault address, an outstanding signed withdrawal can remain valid and execute against the replacement vault, which can receive the Safe's approved Midas tokens if it satisfies the mToken check.

Recommendations: Preserve registration history across removal and require the RoleRegistry owner to approve re-registration of previously configured tokens. Bind the vault address or a configuration version into withdrawal signatures so route changes invalidate outstanding authorizations.

Customer Response:

Fixed in commit 91ac3252

Fix Review:

Fixed

Informational Issues

I-01: Misplaced NatSpec for setSettlementDispatcher

Files:

src/modules/cash/CashModuleSetters.sol

Description:

The newly added isAllowedLendRecipient function and its documentation sit between setSettlementDispatcher and the NatSpec intended to describe it. This separates the setter from its documentation and makes the comments' intended association unclear to readers and documentation tooling.

Recommendations:

Move the setSettlementDispatcher NatSpec block immediately above its function declaration.

Customer Response:

Fixed in commit 91ac3252

Fix Review:

Fixed

I-02: Mixed return and revert behavior in validateRegistration

Files:

src/modules/lend-gateway/LendReserveLib.sol

Description:

validateRegistration returns false when the asset is already registered with the same reserve ID, but reverts for a zero asset address, an underlying asset mismatch, or an existing reserve still in use. Its boolean therefore indicates whether registration changes state, rather than whether validation succeeds. Combining these responsibilities under a validation function can confuse callers expecting a consistent validation result.

Recommendations:

Consider separating the no-op check from the validation.

Customer Response:

Fixed in commit 91ac3252

Fix Review:

Fixed

I-03: ADMIN_TIMELOCK_ROLE can authorize drivers to force leverage across all Safes

Files:

src/modules/lend-gateway/LendGateway.sol

Description:

Although adding a default module requires the RoleRegistry owner, LendGateway can act on every Safe and ADMIN_TIMELOCK_ROLE can authorize its drivers through setDriver. An authorized driver can borrow against any Safe that has not opted out, with the Safe as recipient, without enforcing the configured minimum health factor or requiring per-Safe consent. A driver can also supply a Safe's loose registered balance as collateral. This can impose unwanted debt and leave collateral exposed to liquidation.

Recommendations:

Consider requiring the RoleRegistry owner to authorize drivers.

Customer Response:

Fixed in commit 91ac3252

Fix Review:

Fixed





Disclaimer

Even though we hope this information is helpful, we provide no warranty of any kind, explicit or implied. The contents of this report should not be construed as a complete guarantee that the contract is secure in all dimensions. In no event shall Certora or any of its employees be liable for any claim, damages, or other liability, whether in an action of contract, tort, or otherwise, arising from, out of, or in connection with the results reported here.

About Certora

Certora is a Web3 security company that provides industry-leading formal verification tools and smart contract audits. Certora's flagship security product, Certora Prover, is a unique SaaS product that automatically locates even the most rare & hard-to-find bugs on your smart contracts or mathematically proves their absence. The Certora Prover plugs into your standard deployment pipeline. It is helpful for smart contract developers and security researchers during auditing and bug bounties.

Certora also provides services such as auditing, formal verification projects, and incident response.